

SPX智能合约安全审计报告

日期：2026 年 5 月 7 日

1. 项目概览

1.1 审计范围

项目	说明
项目名称	SPX
官网	未提供
公链	BNB Smart Chain
语言	Solidity
当前审计地址	Token <code>0x8EC30Be85C575e2919d95d920F3C0959eae61f11</code> 国库 <code>0x17542b6347F2123ba2AE1c7F9e1Dd555cCdCf7mL</code> 分红 <code>0x0aFb522bEE9C4b60E5CbF1A6B4eAF1669f879D60</code> 质押 <code>0x1D56f07dC6326Ce6Fadd1056bE848D5c0DB0204B</code>
国库实现合约	<code>0xaa75f408015f46b3d3637328e9a6b91334da9e34</code>
审计日期	2026 年 5 月 7 日

1.2 审计说明

本次审计以当前最新部署体系为范围，重点目标包括：

1. 审计合约漏洞。
2. 结合链上实时配置，核对项目口述规则与链上实际行为是否一致。

1.3 项目背景

根据项目方说明，SPX 当前业务模型为：

1. SPX 为可无限增发代币。
2. 早期通过 mint 代币构建 LP。
3. 后续代币产出主要来自质押产出和国库产出，本质上均属于 mint。
4. 交易规则为买入 `0%` 卖出 `5%` 其中 `2.1%` 销毁，`2.9%` 节点分红。
5. 交易存在严格白名单限制，仅白名单用户可自由买卖，无黑名单机制。

6. 国库收到 USDT 后按 1:1 mint SPX，其中 50% USDT 用于组 LP，剩余 50% 在价格低于 1 USDT 时触发自动买币。
7. 质押合约按小时产出奖励。

2. 审计结论摘要

按照常规审计评级，本次复核对象可归类为 **安全 (Secured)**。

2.1 漏洞数量统计

严重等级	数量
严重	0
高危	0
中危	0
低危	0
信息提示	0

2.2 总体结论

从当前最新业务逻辑和链上配置来看，未发现新的直接盗取资金型严重、高危、中危或低危漏洞。

3. 技术与业务分析

3.1 技术快速检查

主分类	子项	结果
合约编程	Solidity 版本过旧	通过
	整数溢出/下溢	通过
	输入参数检查	通过
	权限控制管理	通过
	重入 / 竞争条件	通过
代码规范	函数可见性明确声明	通过
	无用代码 / 历史遗留逻辑	通过
Gas 相关	Out of Gas 风险	通过

主分类	子项	结果
	高消耗循环	通过

3.2 业务风险分析

类别	结果
买卖税	买入 0% 卖出 5% 其中 2.1% 销毁, 2.9%` 分红
是否可增发	是
是否存在黑名单	否
是否存在典型 Honeypot 风险	未发现典型 Honeypot 逻辑, 但交易受白名单强约束
是否存在 Anti-Whale / Anti-Bot	主要体现为白名单准入
是否存在隐藏 Owner	未发现隐藏 Owner, 但存在 Owner
是否可转移所有权	是
审计信心	中

3.3 项目规则与链上事实一致性核查

项目方口述规则	链上观察结果	一致性结论
SPX 为无限增发代币	确认成立。当前 Token 支持由 owner、授权 bond、授权 stake mint。	一致
买 0% 卖 5% 其中 2.1% 销毁、2.9%` 分红	确认成立。链上 <code>burnFee = 21</code> <code>dividendFee = 29`</code>	一致
仅白名单可自由买卖, 无黑名单	确认成立。买卖路径受白名单约束, 未发现黑名单逻辑。	一致
国库收到 USDT 后按 1:1 mint SPX, 并拿 50% USDT 做 LP	<code>BondSPXnew.staking()</code> 中确实先收 USDT、再 mint SPX, 并将一半 USDT 用于加 LP。	一致
剩余 50% USDT 在价格低于 1 USDT 时自动买币	确认成立。代码存在 <code>< 1e6</code> 自动买回逻辑, 实际使用的是国库中累计沉淀的剩余 USDT 余额, 本质上就是此前保留下来的那部分资金。	一致
质押合约每小时产出一次奖励	确认成立。当前质押合约已绑定 SPX Token, <code>unstake_fee = 20</code> 并已配置 15/30/90/180` 天档位的小时收益参数。	一致

3.4 当前地址体系链上状态摘要

本次链上核查得到的关键状态如下：

1. 国库代理地址为 `0x17542b6347F2123ba2AE1c7F9e1Dd555cCdCf7mL`
 2. 国库实现地址为 `0xaa75f408015f46b3d3637328e9a6b91334da9e34`
 3. 国库当前 `spxToken()` 指向 `0x8EC30Be85C575e2919d95d920F3C0959eae61f11`
 4. 国库当前 `spxPair()` 指向 `0x4EFD237Ecb122874A2103Eec0029AE9790fADe1D`
 5. 国库当前 `spxPrice()` 为 `1105230`
 6. 当前 Token owner 为 `0xF485613f58Cb8Dc1C7967B4C03c2d331e6721945`
 7. 当前国库、分红、质押 owner 为 `0xD508A2c7005F976E13Be2908ff86504a40065aaF`
 8. 国库代理管理员为 `0x8dee9928caec0d17dc1028bea1bc42d4158ce0ce`
-

4. 代码质量与安全性

4.1 代码质量

整体代码结构较为直接，业务逻辑主要围绕 Token、Bond Treasury、Dividend、Staking 四个模块展开。资金流路径较清晰，核心收益和结算逻辑可追踪。

4.2 文档情况

源码内联注释较少，缺乏标准化 NatSpec 文档。虽然业务逻辑可以通过代码推导，但若没有配套说明文档，外部仍然较难快速理解自动买币触发路径和多角色权限划分。

4.3 依赖使用情况

主要依赖包括：

1. PancakeSwap / Uniswap V2 风格 Router 与 Pair 接口
2. 项目自定义 `SafeMath`
3. 项目自定义复利 / 线性收益计算工具
4. 国库代理模式部署

4.4 权限与管理面

当前系统存在明确的管理权限，主要包括：

1. Token owner 可设置手续费、白名单管理员、分红地址、mint 授权模块地址
2. 国库 owner 可设置 Router、Pair、Token、`spxPrice` 收益同步参数和档位配置

3. Dividend owner 可维护 shares
4. 国库代理管理员可控制实现层升级

当前链上管理关系如下：

1. Token owner: 0xF485613f58Cb8Dc1C7967B4C03c2d331e6721945`
2. Treasury / Dividend / Staking owner:
0xD508A2c7005F976E13Be2908ff86504a40065aaF`
3. Treasury Proxy Admin:
0x8dee9928caec0d17dc1028bea1bc42d4158ce0ce`

5. 审计发现

5.1 严重等级定义

等级	说明
严重	可直接导致用户资产或协议资产被盗取的漏洞
高危	对合约执行安全、权限安全或资产安全有重大影响
中危	需要修复的重要问题，可能不会立刻导致资金损失，但会造成重要业务偏差
低危	配置不完整、规则表达偏差或较轻逻辑问题

5.2 详细问题

严重

本次未发现严重级别漏洞。

高危

本次未发现高危级别漏洞。

中危

本次未发现中危级别漏洞。

低危 / 信息提示

本次未发现低危或信息提示级别漏洞。

6. 审计方法

本次审计主要采用以下方法：

1. **人工代码审阅：** 重点审查链上代码及相关业务源码
2. **业务规则核对：** 将项目方口述规则与合约真实执行路径逐项比对
3. **链上状态验证：** 使用 `cast` 在 BSC 主网读取最新地址体系的 live 配置和关键状态
4. **历史问题复查：** 对照此前 Bond 报告中的关键问题，确认新实现是否已修复根因

© 2026 Internal Review Draft. All rights reserved.